

ResolvX

Secure Software Development Lifecycle Policy

Topic-Specific Policy - Secure Design, Coding & Testing Standards

POL-018 · v1.0 · 2026 · Internal : Restricted

Document Information

Policy ID	POL-018
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	DevSecOps
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Frameworks	ISO 27001:2022 A8.25–A8.30, A8.33, A8.34 · NIST CSF 2.0 PR.PS-06 · SOC 2 CC8.1

1. Purpose

This Secure Software Development Lifecycle (SSDLC) Policy establishes how security is built into ResolvX's software from design through deployment, rather than checked for afterward.

Software built by a fintech dispute-resolution platform carries security expectations at every phase of development, not only at the point of release. This policy defines the security activities required at each SDLC phase, the baseline security requirements every feature must meet, and how ResolvX handles the two development activities that carry distinct risk such as using production-like data in lower environments and working with outsourced or contracted developers.

2. Scope

This policy applies to:

- All application code developed by ResolvX engineering, from initial design through production deployment and ongoing maintenance.
- Infrastructure-as-code, to the extent it defines application-facing infrastructure.
- Code developed by contractors or outsourced development partners, per §7.

Code review, testing gates, and the environment path a change follow are governed operationally by the Change Management Policy (POL-013); this policy governs what security activity happens within that path, not the change-control mechanics themselves.

3. Security by SDLC Phase

Phase	Required Security Activity
Requirements	New features handling Restricted or Confidential data (per POL-004) have security and privacy requirements defined alongside functional requirements, not added afterward.
Design	Features with significant attack surface or handling Restricted-tier data undergo threat modelling per §5 before implementation begins.
Implementation	Code follows the secure coding standard in §4; no hardcoded secrets, credentials, or API keys in source (enforced via Snyk secret scanning per POL-010 §6.1).
Testing	SAST, SCA, and container scanning run automatically in CI/CD per POL-010; a Critical or High finding blocks merge, consistent with POL-013's change gating.
Deployment	Deployment follows the standard or emergency change path defined in POL-013.
Maintenance	Dependencies and base images are kept current per the standards in POL-011 §6; findings are remediated per POL-010's SLA.

4. Secure Coding Standard

Engineering follows the OWASP Top 10 and OWASP Application Security Verification Standard (ASVS) as the baseline reference for common vulnerability classes; injection, broken authentication, broken access control, and related categories are treated as defects to prevent by design, not issues to catch only through scanning.

- Input validation and output encoding are applied at every trust boundary, not assumed to be handled upstream.
- Authentication and session handling follow the standards already defined in POL-003 and POL-012.
- Cryptographic functions use vetted, standard libraries; custom cryptographic implementations are not permitted without CISO approval.
- Peer code review (per POL-013 §4) includes a security review dimension, not only a functional correctness review which is where the reviewer considers whether the change introduces a new trust boundary, data exposure, or privilege change.

5. Threat Modelling

A lightweight threat modelling exercise is required before implementation begins for any feature that:

- Introduces a new external-facing API or authentication mechanism.
- Handles Restricted-tier data in a new way (e.g., a new export, integration, or reporting capability).
- Changes a trust boundary between ResolvX systems and a third party.

The exercise identifies the feature's attack surface, likely threat actors and their goals, and the mitigations design, this is documented briefly as part of the feature's design review, not as a separate lengthy process. VP Engineering confirms threat modelling occurred for in-scope features as part of design sign-off.

6. Test Data Protection

Staging holds internal/test data and development holds only synthetic data, consistent with ResolvX's existing environment classification. This policy makes that a binding requirement, not a description of current practice:

- Production Restricted-tier data (client PII, financial account data) is never copied into development environments.
- Where realistic data volume or shape is needed for staging validation, data is synthetically generated or anonymised/masked, no direct production copy used.
- Any exception (e.g., reproducing a production-specific bug) requires GRC Lead approval, is time-limited, and the data is deleted from the lower environment once the exception's purpose is fulfilled.

7. Outsourced & Contracted Development

Code from a contractor or outsourced development partner is not treated as trusted by default, it enters the same pipeline as internally authored code:

- Contracted code is submitted through the same pull request, review, and CI/CD scanning path as internal code as there is no separate, lighter-touch merge path for contractor contributions.
- Contracts with development partners include confidentiality, IP assignment, and security requirement clauses consistent with the vendor security expectations set in POL-005.
- VP Engineering confirms a contractor's access is scoped to only the repositories and environments their engagement requires and revoked at engagement end per POL-011 §8.

8. Protection During Security Testing

External penetration testing or vulnerability assessment activity against ResolvX systems is scoped and authorised in advance:

- Rules of engagement define in-scope and out-of-scope systems explicitly, production Critical-tier systems require CISO sign-off before inclusion.
- Head of Cloud Ops is notified of testing windows in advance, so that expected test activity is not mistaken for a genuine security incident.
- Findings from external testing are logged in the Corrective Action Plan and follow the same severity-based SLA as any other vulnerability finding under POL-010.

9. Roles & Responsibilities

9.1 DevSecOps

- Owns this policy and the secure coding standard (§4).
- Maintains the CI/CD security gates referenced in §3.

9.2 VP Engineering

- Confirms threat modelling occurred where required (§5).
- Scopes and manages contractor access (§7).

9.3 GRC Lead

- Approves test data exceptions (§6).
- Coordinates authorisation for external security testing (§8).

9.4 CISO

- Approves any custom cryptographic implementation (§4) and any Critical-tier system's inclusion in external testing scope (§8).

10. Compliance and Enforcement

Production Restricted-tier data found in a development environment, code merged without required security scanning, or external testing conducted without authorised scope, is treated as a control deficiency and logged in the Corrective Action Plan.

11. Document Control

Policy ID	POL-018
Version	1.0
Status	Active
Classification	Internal - Restricted
Owner	DevSecOps
Approver	CISO
Review Cycle	Annual
Next Review	Q3 2027
Framework References	ISO/IEC 27001:2022 A8.25, A8.26, A8.27, A8.28, A8.29, A8.30, A8.33, A8.34 · NIST CSF 2.0 PR.PS-06 · SOC 2 TSC CC8.1
Related Documents	POL-003 (Access Control Policy), POL-004 (Data Classification Policy), POL-005 (Vendor Management Policy), POL-010 (Patch Management Policy), POL-011 (Asset Management Policy), POL-012 (Password Policy), POL-013 (Change Management Policy)

ResolvX GRC Program — Internal Use Only — v1.0 — 2026

Authorisation

Role	Name	Date
CEO		
CISO		
GRC Lead		